

CyberDefense Pro 2.0

2.1.4 Regulations and Standards Facts

Many regulations describe their legal authority and also include details describing compliance requirements without referencing a separately maintained standard. Examples include the General Data Protection Regulation (GDPR) and Children's Online Privacy Protection Act (COPPA), which are both focused on protecting privacy information.

This lesson covers the following topics:

- Using legal contracts to require standards compliance
- Payment Card Industry Data Security Standard (PCI DSS)
- Capability Maturity Model Integration (CMMI)
- Cloud Security Alliance (CSA) STAR certification
- Children's Online Privacy Protection Act (COPPA)
- General Data Protection Regulation (GDPR)

Using Legal Contracts to Require Standards Compliance

Legal contracts can often be used to enforce compliance with external standards or to identify other similar requirements, such as demonstrating that internal programs closely align to industry best practice frameworks. Some examples that fall into this category of agreement include PCI-DSS, CMMI, and CSA STAR.

Payment Card Industry Data Security Standard (PCI DSS)

The Payment Card Industry Data Security Standard (PCI DSS) is a global data protection standard established and maintained by a consortium of payment card companies. PCI DSS is an important security measure for businesses that accept credit and debit cards. It is a set of requirements developed by the Payment Card Industry Security Standards Council to help ensure that all companies that handle, process, or store cardholder data do so securely. PCI DSS identifies controls and outlines the measures that must be taken to protect customer data and prevent fraud. From establishing secure networks to regularly testing security systems, PCI DSS is designed to protect customer data and reduce the risk of cybercrime.

The benefits of following PCI DSS standards include protecting customer data and reducing the risk of fraud. Organizations should be aware of the potential risks associated with storing and processing payment card information and be prepared to take action to reduce those risks. Following the PCI DSS provides a baseline from which a company can build an effective security program. The following are some other advantages of PCI DSS:

- Following the PCI DSS ensures that cardholder data is appropriately safeguarded and can reduce the risk of data breaches and other security incidents.
- Customers may be more likely to do business with companies with a robust security program to protect their data.
- A robust security program can help reduce the costs associated with PCI compliance, data breach investigations, and other security-related expenses.

PCI DSS Implementation

The PCI DSS outlines 12 main requirements:

1. Install and maintain a firewall.
2. Do not use vendor-supplied defaults for system passwords and other security parameters.
3. Protect all systems against malicious code.
4. Use and regularly update antivirus software.
5. Develop and maintain a secure web application and data transmission.
6. Protect all systems against loss and unauthorized access.
7. Regularly monitor and test networks.
8. Track and monitor all system components.
9. Employ strong password management.
10. Regularly review and assess the PCI DSS compliance status.
11. Maintain a PCI compliance policy.
12. Maintain a PCI compliance program with written management authorization.

Each requirement details many individual controls, and implementing them is a complex task requiring careful planning and effective time management. Generally, implementing PCI DSS should follow four main phases:

- **Assess:** The first step is to assess the current state of PCI DSS within the organization, for example, identifying security risks, such as the transmission of cardholder data across an unsecured network.
- **Plan:** The organization should develop a plan to implement PCI DSS requirements. This plan should include timelines, milestones, and the people responsible for each task.

- **Execute:** Once the plan is in place, it is time to execute it. This means putting the appropriate security measures in place and following the PCI DSS requirements.
- **Maintain:** Finally, the organization should maintain PCI DSS compliance on an ongoing basis. This means regularly reviewing and testing systems, following an approved change management process, and documenting PCI DSS compliance status.

A copy of the PCI DSS can be obtained free from the PCI Security Standards website:

https://www.pcisecuritystandards.org/document_library .

PCI DSS Compliance

Organizations that take credit and debit cards are required to follow the standards described within the PCI DSS. Every organization that accepts payment by credit or debit card works continuously to maintain PCI DSS compliance and, in light of this, the PCI DSS standard identifies that organizations must be audited regularly. Audit frequency depends on the level of risk within the organization. For example, lower-risk organizations that do not perform many credit card transactions may be audited once per year, while high-risk organizations may need to be audited once per quarter. Compliance is generally measured on a continuum of implementation. An organization that fully complies with PCI DSS requirements is at one end of the continuum, and an organization that meets none is at the other. A PCI Attestation of Compliance (AoC) is a document designed to demonstrate an organization's compliance with PCI DSS requirements. The AoC should be completed by a Qualified Security Assessor (QSA) or the merchant (such as a bank) responsible for processing credit and debit card transactions. A QSA is certified by the Payment Card Industry Security Standards Council (PCI SSC) to perform PCI DSS audits and measure PCI compliance.

The organization being audited is responsible for covering the costs of the audit. If an organization fails the audit, the organization conducting the audit will provide the PCI Security Standards Council with a detailed report outlining the level of noncompliance within the organization. This report is then published on the PCI Security Standards Council website. The organization will receive a failing grade on its PCI Compliance Report and must address the issues raised in the audit report before it can be resubmitted for reaudit.

Capability Maturity Model Integration (CMMI)

Capability Maturity Model Integration (CMMI) describes five levels of maturity within the operational or software capabilities of an organization. Measuring software capabilities is the most common use, and this assessment is frequently required by many federal contracts. A CMMI assessment is very focused on identifying that all work is defined through well-established processes. The results of the

assessment will establish the maturity level, or score, of an organization. The scores include the following:

- **Level 1: Initial** —Processes do not exist, and work is reactive in nature.
- **Level 2: Managed** —Many work activities are defined via processes, but work is still frequently reactive in nature.
- **Level 3: Defined** —The majority of work is well defined via processes, and proactive measures are in place.
- **Level 4: Quantitatively Managed** —All work is well defined via processes, proactive measures are in place, and the work outputs are tracked and analyzed.
- **Level 5: Optimizing** —Work is well defined via processes, and work is proactive, measured, analyzed, and continuously improved.

Cloud Security Alliance (CSA) STAR Certification

The Security, Trust & Assurance registry is maintained by the Cloud Security Alliance. The publicly available registry includes CSA STAR assessment details for many cloud service providers. A CSA STAR evaluation measures the security capabilities and privacy controls of a cloud service provider against the CSA Cloud Controls Matrix (CCM). Additional details regarding CSA STAR assessments, as well as links to the public registry, are available via: <https://cloudsecurityalliance.org/star>. The CCM is available via: <https://cloudsecurityalliance.org/research/cloud-controls-matrix/>.

Children's Online Privacy Protection Act (COPPA)

The Children's Online Privacy Protection Act (COPPA) is a U.S. federal law designed to protect the privacy of children (inside and outside of the United States) under the age of 13. It requires operators of websites or online services to provide clear privacy policies, details when consent from a parent or guardian is required, and also a description of the operator's responsibilities to protect information from being used for marketing purposes.

General Data Protection Regulation (GDPR)

The General Data Protection Regulation (GDPR) enforces rules for organizations that offer services to entities in the European Union (EU) or that collect and/or analyze data on a subject located there. GDPR rules are stringent and apply no matter where the originating organization operates from or where the collected data is stored. Failure to comply with GDPR rules results in extremely costly fines.

There are seven principles of the GDPR:

- Lawfulness, fairness, and transparency
- Purpose limitation
- Data minimization
- Accuracy
- Storage limitation
- Integrity and confidentiality (security)
- Accountability

Copyright © CompTIA, Inc. All rights reserved.